

ISYS90090 · CYBERSECURITY MANAGEMENT

Security Strategy & Defence in Depth

Nine paradigms, how they combine,
and where the weakest link sits.

Week 9 · Atif Ahmad · University of Melbourne



This Week in Cybersecurity Management

01

Study the
Canvas
module

02

Complete the
prescribed
reading

03

OPTIONAL

Answer
discussion
questions on
Canvas, and
chat with
peers

04

Attend the
workshop

05

OPTIONAL

Continue the
discussion
with peers on
Canvas

This week's workshop

PART A

Q&A session on this
week's content

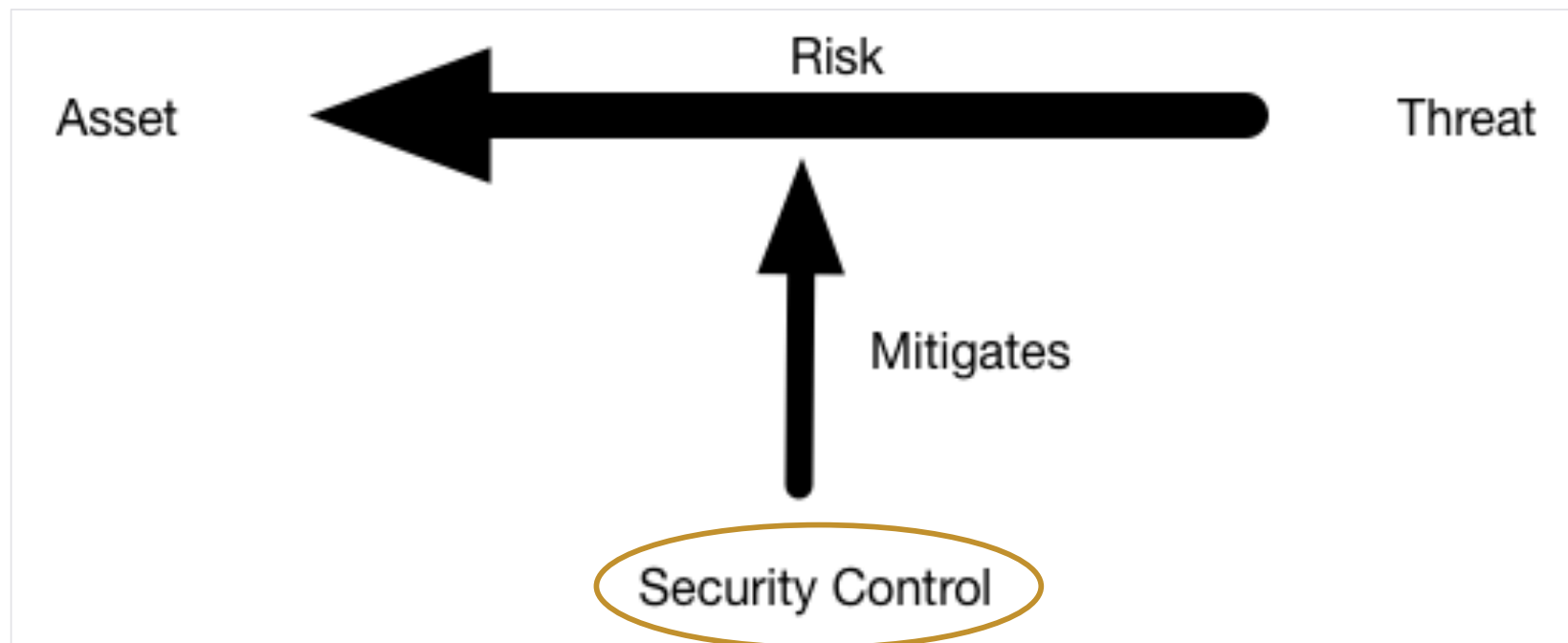
PART B

Exam Preparation

Intended Learning Objectives

- 01 Identify a range of security paradigms that can be employed for security purposes
- 02 Distinguish between strategy, tactics and operations
- 03 Consider how security paradigms can be combined to form defence in depth
- 04 Draw parallels between the security artefacts involved in defending a castle and the security countermeasures employed in an organisational network

It all starts from the Triplet Model



Asset ← Risk ← Threat, with the security control mitigating the risk. Strategy is about how those controls are chosen and combined.

Revisiting the definition of strategy

DEFINITION 1

Strategy is the craft of collectively rising to a significant challenge and accomplishing more than might be reasonably expected as a result of self-knowledge, resolve, foresight, creativity and genuine capabilities cultivated over the medium to long term.

DEFINITION 2

Strategy relates to the coherence of the alignment of broad intentions, environmental circumstances and available resources, but the process of assessing alignment should be done in relation to a perceived challenge, opportunity or difficulty.

A definition built for cybersecurity

Strategy is the art and science of deciding how to best utilise appropriate defensive information security technologies and measures, and to deploy and apply them in a coordinated way to defend organisational information resources against internal and external threats by offering confidentiality, integrity and availability at least effort and cost while being effective.

The third definition is particularly relevant and useful.

Why the third definition is the useful one

01	Art and science	It balances both the “art” and “science” aspects, as effective cybersecurity requires both creativity and technical knowledge.
02	Coordinated deployment	It emphasises coordinated deployment, highlighting that individual security measures must work together as a cohesive system.
03	Efficiency	It introduces efficiency by mentioning “least effort and cost while being effective”, which is crucial in resource-constrained environments.
04	Internal and external threats	Unlike the other definitions, it directly addresses both internal and external threats, reflecting the complex threat landscape in cybersecurity.

Cybersecurity paradigms

In this subject we use 'paradigm' to refer to a fundamental approach or model that shapes how we think about and implement security measures. Paradigms are the conceptual building blocks that form the foundation of more comprehensive cybersecurity strategies.

- | | |
|----|----------------------|
| 01 | Prevention |
| 02 | Detection |
| 03 | Response |
| 04 | Deterrence |
| 05 | Surveillance |
| 06 | Deception |
| 07 | Perimeter defence |
| 08 | Compartmentalisation |
| 09 | Layering |

Prevention

Prevention aims to protect information assets prior to an attack by prohibiting unauthorised access, modification, destruction, or disclosure.

The priority is to block attacks by putting 'barriers' around assets in anticipation of attack.

PROTECTING GOLD

Fort Knox

PROTECTING A TURTLE

Its shell

PROTECTING A SATELLITE

(Outer) space

What are some IT prevention measures?

Prevention: how it behaves

ALWAYS ON

Prevention is passive

It is always there, working all the time in the background.

NOT ONLY PHYSICAL

Not all preventive measures are physical

Some computer software is sold with codes built in that prevent it from being copied properly.

Detection & Response

DETECTION

Detection is aimed at noticing behaviours that violate security, to enable response (taking appropriate corrective action) in a targeted manner.

FOR EXAMPLE **An alarm**

RESPONSE

Response takes appropriate corrective actions against identified attacks.

FOR EXAMPLE **Guards**

What are some IT detection and response measures?

Prevention, Detection, Response

Scenario: a document in a room needs to be protected.

PREVENT

A safe (walls + lock)

A useful preventive countermeasure because it can deny an attacker access.



DETECT

An alarm

A useful detection countermeasure because it detects the presence of an attacker.



RESPOND

Guards

A useful response countermeasure.

Combining the three

A safe provides defence, but works better with alarms and guards.

Weak prevention means you need better detection and response.

HOW STRONG A SAFE DO YOU NEED?

TL-30

Resists a professional safecracker for at least 30 minutes

TRTL-60

Resists a safecracker with an oxyacetylene torch for 60 minutes

Can you think of how the three paradigms can be combined in the context of IT security?

Deterrence

Deterrence employs disciplinary action to influence human behaviour and attitude.

INFLUENCED BY · FACTOR 1

Certainty of sanctions

INFLUENCED BY · FACTOR 2

Severity of sanctions

How is deterrence most commonly implemented in organisations?

Surveillance

Surveillance is the systematic monitoring of the security environment towards developing situational awareness, to assist in adapting to fast-changing circumstances and threats.

Example: CCTV used to monitor the surroundings of the organisation.

Surveillance

Broader aim: to understand the environment

Detection

Narrower aim: to identify a specific behaviour

What are some IT surveillance measures?

Deception

Deception distracts an attacker's attention from its goal by using decoys or equivalent, to lead the attacker to waste time and resources.

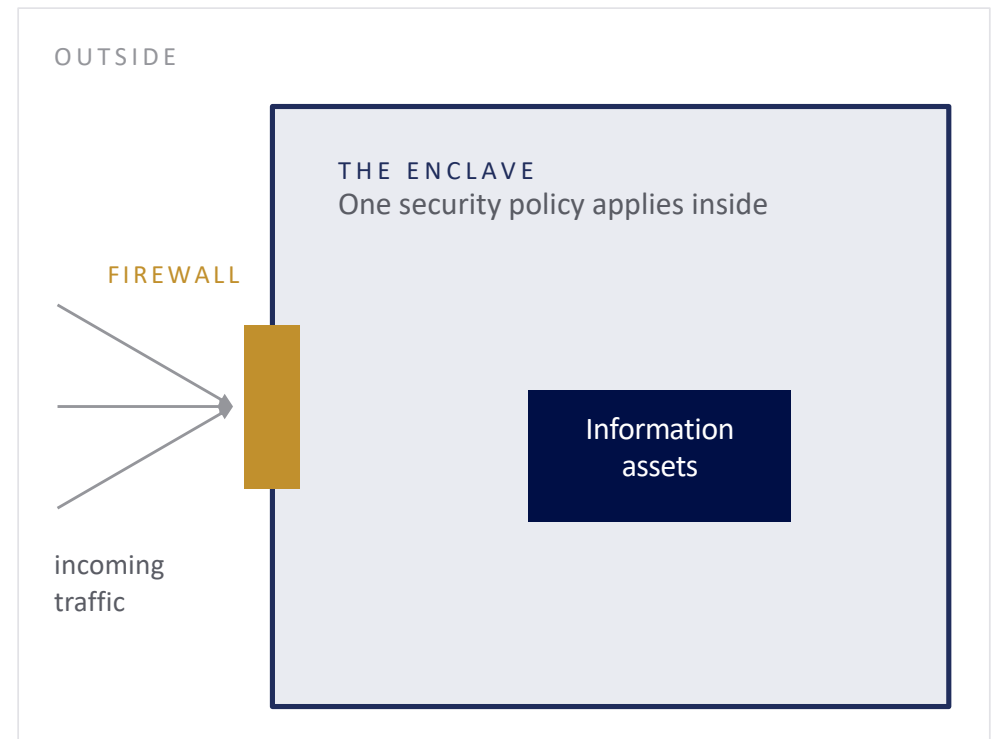
QUESTION FOR THE ROOM

What are some ways to use deception in IT security?

Perimeter defence

A physical or logical boundary defined for a domain or enclave, within which a security policy or security architecture applies.

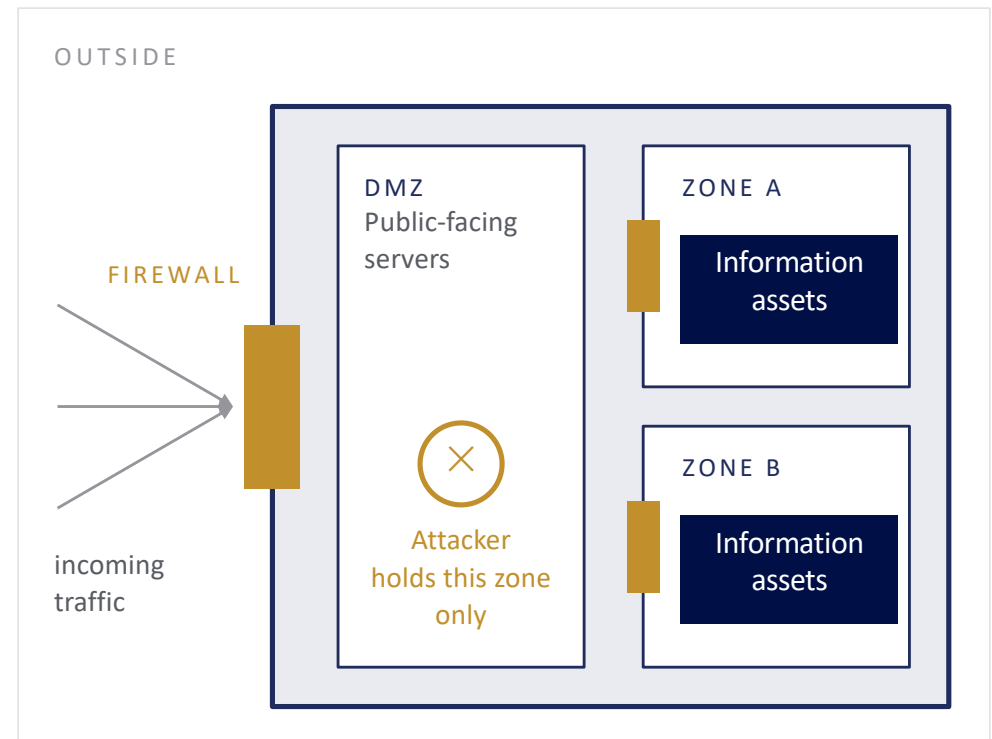
In information security this technique is commonly used by means of a firewall choking off incoming traffic to information assets.



Compartmentalisation

Compartmentalisation limits an attacker's opportunities by dividing the target area into zones that are secured separately.

This way, an attacker with access to one zone does not automatically get access to other zones. A typical example is a DMZ.



Layering, or defence in depth

Multiple barriers

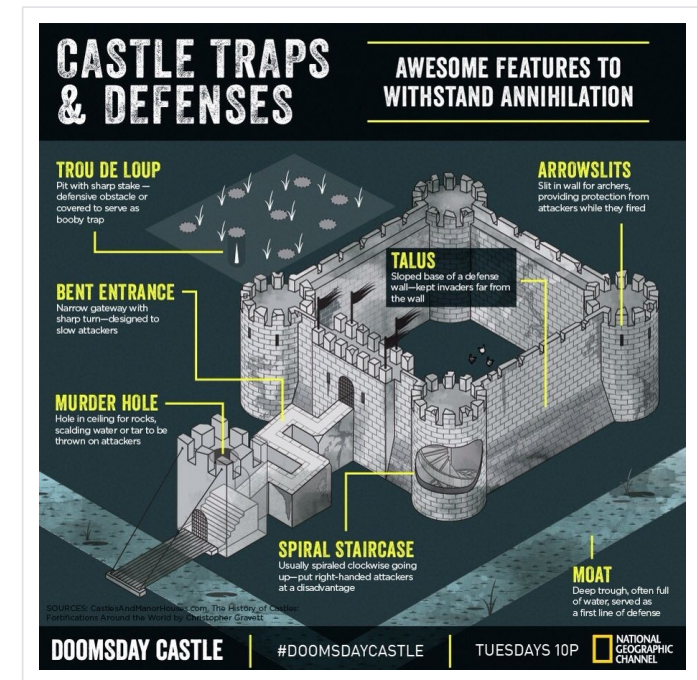
Layering constructs multiple barriers that complement each other, increasing the effectiveness of the defensive system.

One is not enough

This strategy is predicated on the belief that a single strategy is insufficient.

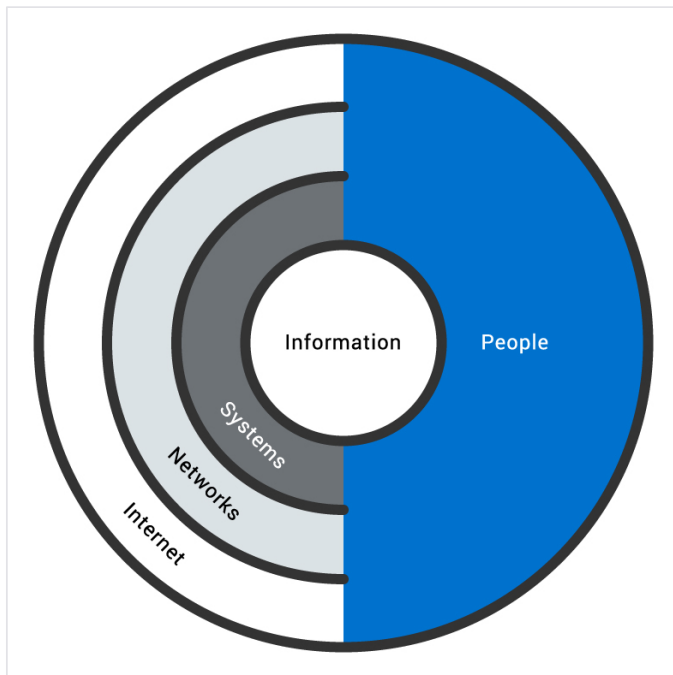
Resilient by design

The system is resilient because it overlaps countermeasures, so that if one fails another backs it up. An example follows.

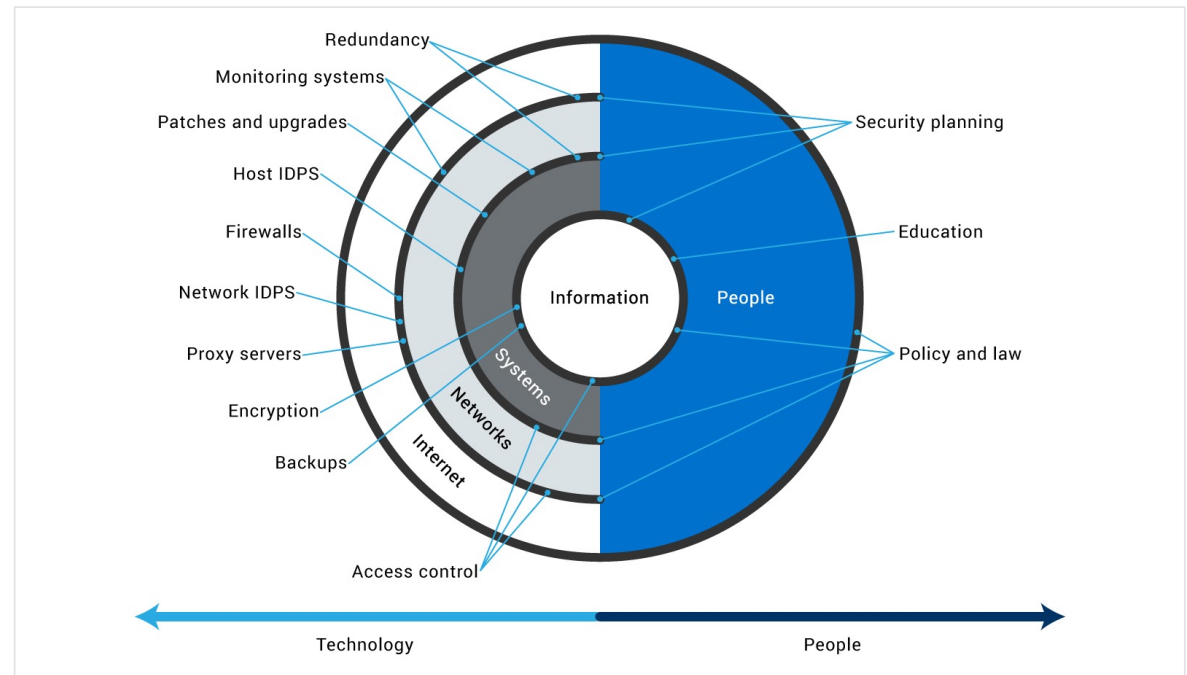


Castle traps and defences. National Geographic Channel.

Defence in depth applied to cyber



Sphere of use



Sphere of protection

Finding the castle in the network

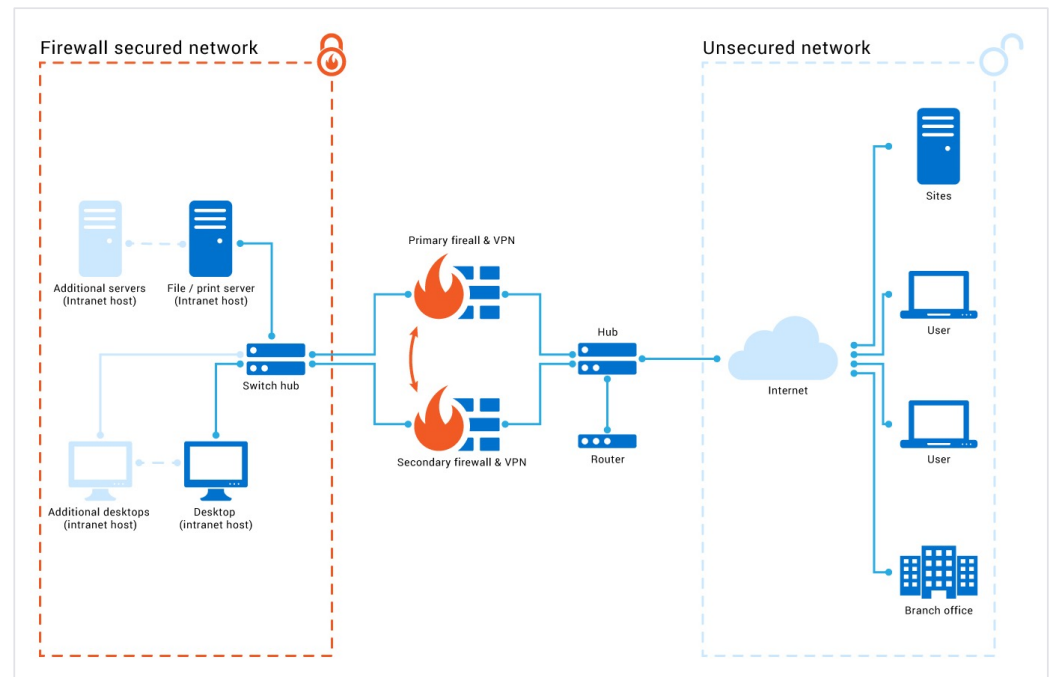
LOOK AT THE DIAGRAM AND ASK

01 Where are the perimeter walls?

02 Where is the drawbridge?

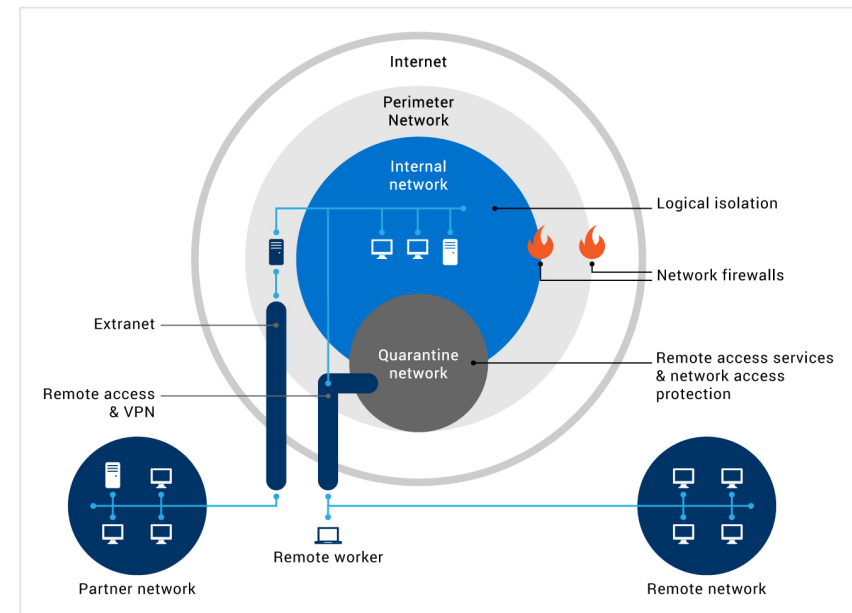
03 Where is the inside of the castle?

04 Where is the king?



Defence in depth

- Multiple firewalls create a concentric network
- Air gaps can make digital penetration impossible, requiring physical penetration
- Proxies can also take advantage of a concentric design
- Extra layers can be created artificially to separate skill levels, reversing asymmetric leverage
- IDS and access control provide further layers of security



In principle, key assets should be positioned behind as many layers as possible.

How the pieces connect

NOTE

- 01 Central role of strategy
- 02 Multifaceted approach: process, tactics, culture
- 03 Interconnectedness between elements of cyber
- 04 Balance of proactive and reactive measures
- 05 Layered security is key
- 06 Risk management is central to management
- 07 Controls are of varying types
- 08 Environmental factors
- 09 Continuous process
- 10 Cultural aspect



Security through obscurity

THE CHALLENGE

Crack this safe!

- 01 I won't tell you where it is...
- 02 I won't tell you what kind of safe it is...
- 03 I won't tell you what security measures are waiting for you...

THE QUESTION

Is this
'security'?

The weakest link principle

“A chain is no stronger than the weakest link.”

- No matter how strong the strongest links in a chain, the chain will break at its weakest link first when put under pressure.
- In effect, the chain is as strong as its weakest link, and any effort spent strengthening the stronger links is wasted.

Example: a typical residential house

But which 'weakest link' did you find?

Your attacker may not agree with your point of view when it comes to the weakest link.

The petty thief thinks differently to the assassin. They will exploit different links depending on a range of factors.

ASK ABOUT YOUR ATTACKER

01

Are they familiar with the make and model of the padlock?

02

Are they more experienced with roof entry?

03

Are they willing to kill?

Shared security: one weak link affects all

IMAGINE

A town's 100 families build a common security wall around their homes.

- Each family is responsible for its part of the wall.
- Ninety-nine families build their walls tall and strong, but one family decides to slack off and builds a short wall.
- Was the effort of the ninety-nine families useful? Can they afford to 'mind their own business'?

It's easy to see which part of the wall is inadequate.

But can you see which firewall is inadequate?

Q&A

Questions on strategy, paradigms
and defence in depth.

ISYS90090 · Cybersecurity Management · Week 9

